

BOTIUM TOYS

Internal Security Audit

Controls & Compliance Assessment

RISK SCORE 8 / 10 - HIGH	ASSESSMENT TYPE Internal Security Audit	FRAMEWORK NIST CSF
-----------------------------	--	-----------------------

Executive Summary

Botium Toys is a fictional U.S.-based toy company with a growing online presence and customers in the United States and European Union. This internal security audit reviews the organization's current controls and compliance posture using the provided risk assessment. The assessment identified a high overall risk score of 8/10, driven by significant gaps in access control, protection of sensitive payment data, detection capabilities, and recovery preparedness.

Scope and Objectives

- Review the security controls protecting Botium Toys' physical and digital assets.
- Assess current practices against PCI DSS, GDPR, and SOC-related control expectations.
- Identify control gaps that could expose customer data, payment information, systems, or business operations.
- Recommend prioritized improvements that reduce risk and strengthen the organization's security posture.

Controls Assessment

Control	Status		Audit Evidence / Finding
	YES	NO	
Least privilege		NO	Not implemented; employees have overly broad access to internally stored data.
Disaster recovery plans		NO	No disaster recovery plans are currently in place.
Password policies		NO	A policy exists, but current requirements do not meet adequate password complexity expectations.
Separation of duties		NO	Not implemented.
Firewall	YES		A firewall is installed with defined security rules.
Intrusion Detection System (IDS)		NO	An IDS has not been installed.
Backups		NO	Critical data is not backed up.
Antivirus software	YES		Antivirus software is installed and regularly monitored.
Legacy system monitoring & maintenance	YES		Legacy systems are monitored and maintained, although no regular schedule is established.
Encryption		NO	Customer credit-card information is not encrypted.
Password management system		NO	No centralized password-management system is in place.
Locks	YES		The physical location has sufficient locks.
CCTV surveillance	YES		Up-to-date CCTV surveillance is in place.
Fire detection/prevention	YES		Functioning fire detection and prevention systems are in place.

Compliance Assessment

PCI DSS

Best Practice	Status	Finding
Access to cardholder data is limited to authorized users	NO	Employees may have broad access to customer cardholder information.
Cardholder data is handled in a secure environment	NO	Current safeguards are insufficient for sensitive payment data.
Cardholder data is encrypted	NO	Credit-card information is not encrypted.
Secure password-management practices are used	NO	Password requirements are weak and no centralized password manager is in place.

GDPR

Best Practice	Status	Finding
EU customer data is kept private and secure	NO	Sensitive customer information is not adequately protected.
72-hour breach-notification plan exists	YES	A plan exists to notify EU customers within 72 hours of a breach.
Data is classified and inventoried	NO	The assessment identifies a need to classify existing assets/data.
Privacy policies and procedures are enforced	YES	Privacy policies, procedures, and processes have been developed and are enforced.

SOC-Related Controls

Best Practice	Status	Finding
User-access policies are established	NO	Least privilege and separation of duties are not implemented.
Sensitive PII/SPII is confidential and private	NO	Broad employee access increases confidentiality risk.
Data integrity is maintained	YES	Integrity controls have been implemented.
Data is available to authorized users	YES	Availability controls have been implemented.

Key Findings

Priority	Finding
Critical	Sensitive payment data is not encrypted, increasing exposure if systems or databases are compromised.
High	Least privilege and separation of duties are not implemented, resulting in excessive access to sensitive information.
High	No IDS is installed, reducing the organization's ability to identify suspicious network activity.
High	No critical-data backups or disaster recovery plan exist, creating significant business-continuity risk.
Medium	Password requirements are inadequate and no centralized password-management system is used.
Medium	Legacy systems are maintained manually but without a regular maintenance schedule.

Recommendations

- 1. Protect sensitive data:** Encrypt customer credit-card information and other sensitive data both at rest and in transit.
- 2. Strengthen access control:** Implement least privilege so users receive only the access required for their roles.
- 3. Implement separation of duties:** Divide sensitive financial, administrative, and IT responsibilities among authorized personnel so no single individual controls an entire critical process.
- 4. Improve detection:** Deploy an intrusion detection system (IDS) and establish procedures for reviewing and escalating suspicious activity.
- 5. Improve resilience:** Create regular backups of critical data and establish, document, and test a disaster recovery plan.
- 6. Strengthen authentication:** Adopt stronger password requirements and implement a centralized password-management solution.
- 7. Improve asset governance:** Classify and inventory sensitive data and establish a regular maintenance schedule for legacy systems.

Conclusion

Botium Toys has several foundational controls in place, including a firewall, antivirus software, physical locks, CCTV, and fire detection/prevention. However, the absence of key access-control, encryption, detection, backup, and recovery measures leaves the organization at high risk. Prioritizing the recommended controls would reduce exposure of sensitive information, improve incident readiness, and strengthen alignment with applicable compliance expectations.

PORTFOLIO PROJECT DISCLAIMER

This portfolio project is based on a fictional Botium Toys scenario from the Google Cybersecurity Professional Certificate. It demonstrates security-audit, controls-assessment, risk-analysis, and compliance-review skills in a simulated environment.